

Case: Phantom traces

06/01/2026

Executive summary

On September 18, 2025, CISO alerted SOC of a forum post found on the dark web stating a dark web actor established connection and data exfiltration of Phantom Capitals database. Upon further investigation, SOC has confirmed that the breach was not a bluff and Phantom Capital was breached on September 17th, 2025 in the early morning. The attacker established connection using compromised credentials of jmatthews in a brute force attack on phnm-backup03 beginning at 2:41am which then the attacker breached the backup server and logged in at 2:43 am. Within the next ten seconds the attacker executed PSEXESVC, the service used to establish his lateral movements and psexec.exe \\phnm-backup03 -s cmd.exe which allowed them to access the system shell. At 2:44am Splunkforwarder stops and the last splunk connection was established. Accessing the backup machine using RDP xfreerdp /u:soc_analyst /d:PHANTOMCAP /v:10.0.69.253 /cert-ignore /p:'SOC@IncidentHandling' then view event viewer to see that logs were cleared from this machine at 2:54am then at 3:01am there was an attempt to reset soc_analyst password, this could show signs of an attempted backdoor being established. After the machine is searched a bit more to find C:\Temp and the exfiltrated data employee_database.csv and financial_report_2024.xlsx. We now pivot to discover the exfiltration method.

Next, investigate program files and find the phantom capital folder containing the backup service and the files shown how to access the database server of phantomcap-findb01. Pivoting to our original machine and try to establish an ssh connection to the database server with our SOC credentials met with success. We run a bash history on the machine to see what the attacker entered during the time of the attack to find the directory that they attempted to hide under mysqldump -u phnm_backup_svc -p phantom_portfolio_records > /home/phnm_backup_svc/.a/.a/.7f2d9c4e-3b8a-4f1e-9d6c-2a5b8e7f3c1d/.b/exfiltration.sql we navigate to the /exfiltration.sql and enter cat exfiltration.sql to find PHANTOM{complete_database_exfiltration_sep17_2025}. Finding the flag and the scope of the breach which was a complete database exfiltration.

Findings and Analysis

Finding	Finding Details	Description
IP address used to attack	192.168.1.45	IP address that the attacker first used to brute force machine
Breached System	Phnm-backup03	First point attacker gained in network, used to lateral to other machines and database
CMD line activated	command psexec.exe \\phnm-backup03 -s cmd.exe	Line of command attacker used to gain CMD access
Program attacker used to exfil data	phantom_portfolio_records	This was the program the attacker used to exfiltrate the data from the database server
SQL file containing flag	exfiltration.sql	SQL file that contained flag PHANTOM{complete_database_exfiltration_sep17_2025}

Tools and technologies used

- Splunk- SEIMS environment used to monitor endpoints
- WindowsEventViewer- Diagnostic tool to view software and hardware changes on windows machine.
- Nmap – network scanner used to detect host and open ports on network.

Investigation Process

1. We begin by entering index=* EventCode=4625 filtered to beginning of September 2025 to find that jmatthews had several failed log ins at 2:42am

```
> 9/17/25 { [-]
  2:41:00.000 AM Account_Domain: PHANTOMCAP
                  Account_Name: jmatthews
                  Authentication_Package: NTLM
                  Channel: Security
                  ComputerName: phnm-backup03.phantomcap.local
                  EventCode: 4625
                  Failure_Reason: Unknown user name or bad password.
                  IpAddress: 192.168.1.45
                  LogonProcessName: NtLmSsp
                  Logon_Type: 3
                  RecordGuid: 0a64964e-6e97-4a43-9143-f84f4ed8069d
                  TimeCreated: 2025-09-17T02:41:00Z
}
Show as raw text
host = phnm-backup03.phantomcap.local | source = WinEventLog:Security | sourcetype = phantom:winsecjson
```

2. Narrowing the timeframe to 2:41am to 5am using index=* EventCode=4624 we check to see any successful log ins to find jmatthews then logged in at 2:43am

```
> 9/17/25 { [-]
  2:43:00.000 AM Account_Domain: PHANTOMCAP
                  Account_Name: jmatthews
                  Authentication_Package: NTLM
                  Channel: Security
                  ComputerName: phnm-backup03.phantomcap.local
                  EventCode: 4624
                  IpAddress: 192.168.1.45
                  KeyLength: 256
                  LogonProcessName: NtLmSsp
                  Logon_ID: 0xED04E996BA3C
                  Logon_Type: 3
                  RecordGuid: 23051337-053a-4d50-941f-b4677a94f414
                  TimeCreated: 2025-09-17T02:43:00Z
                  WorkstationName: phnm-backup03
}
Show as raw text
host = phnm-backup03.phantomcap.local | source = WinEventLog:Security | sourcetype = phantom:winsecjson
```

3. Next we investigate if any actions were taken on the machine seeing powershell accessed at 2:43:05.000 and by using EventCode=4688 seeing that there was a

suspicious event made at 02:43:10.000

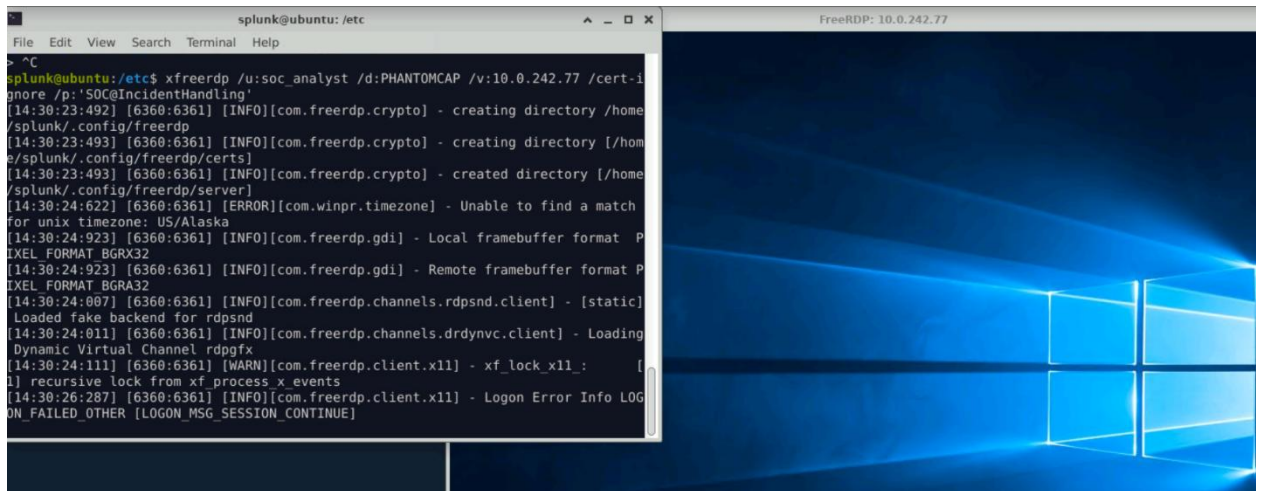
```
> 9/17/25 { [-]
2:43:10.000 AM Account_Domain: PHANTOMCAP
Account_Name: jmatthews
Channel: Security
CommandLine: psexec.exe \\phnm-backup03 -s cmd.exe
ComputerName: phnm-backup03.phantomcap.local
EventCode: 4688
IntegrityLevel: High
NewProcessName: C:\Windows\System32\psexec.exe
ParentProcessId: 0x01D45D
ParentProcessName: C:\Windows\PSEXESVC.exe
ProcessId: 0xC22E68
RecordGuid: 020a6f04-50d2-4bb2-9f3c-abd67645a5f5
TimeCreated: 2025-09-17T02:43:10Z
TokenElevationType: 2
}
Show as raw text
host = phnm-backup03.phantomcap.local | source = WinEventLog:Security | sourcetype = phantom:winsec:json
```

4. Following events, we see SplunkForwarder stops at 2:44:02.000 and then at 2:44:03 the machine loses all Splunk connections

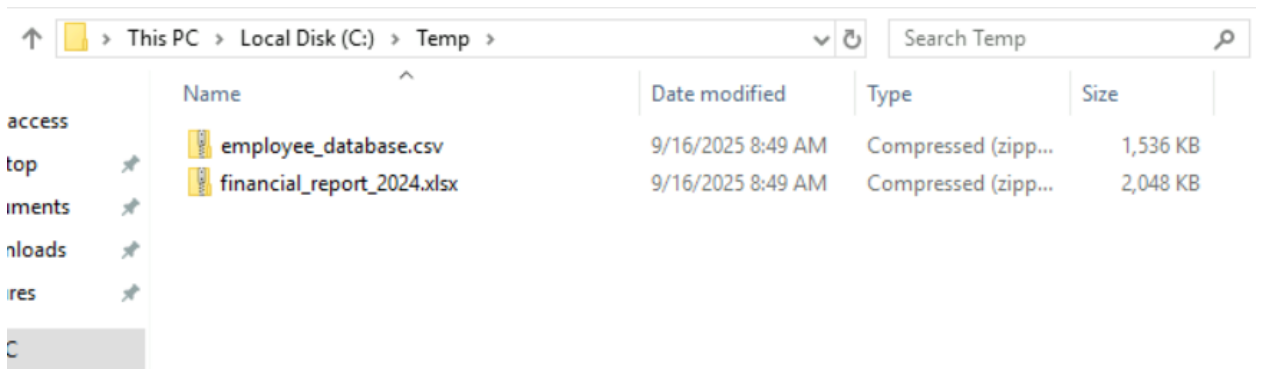
```
> 9/17/25 { [-]
2:44:03.000 AM Account_Domain: PHANTOMCAP
Account_Name: SYSTEM
Channel: Application
ComputerName: phnm-backup03.phantomcap.local
EventCode: 10000
Message: Last Splunk connection lost
RecordGuid: b60e6528-2580-4ed9-825f-6c194ede2467
TimeCreated: 2025-09-17T02:44:03Z
}
Show as raw text
host = phnm-backup03.phantomcap.local | source = WinEventLog:Security | sourcetype = phantom:winsec:json
```

5. Seeing that we have lost all communication with Splunk and this machine, the machine itself needs to be investigated. The simplest option, we check to see if the host ip is saved in the machine by entering /etc directory and cat hosts to see that the data base IP and the compromised machine are both there.
6. Running a nmap scan to check for open ports to see if SSH is viable to which it is not, however we see that port 3389 is open, allowing us to rdp using our soc_anaylst credentials.

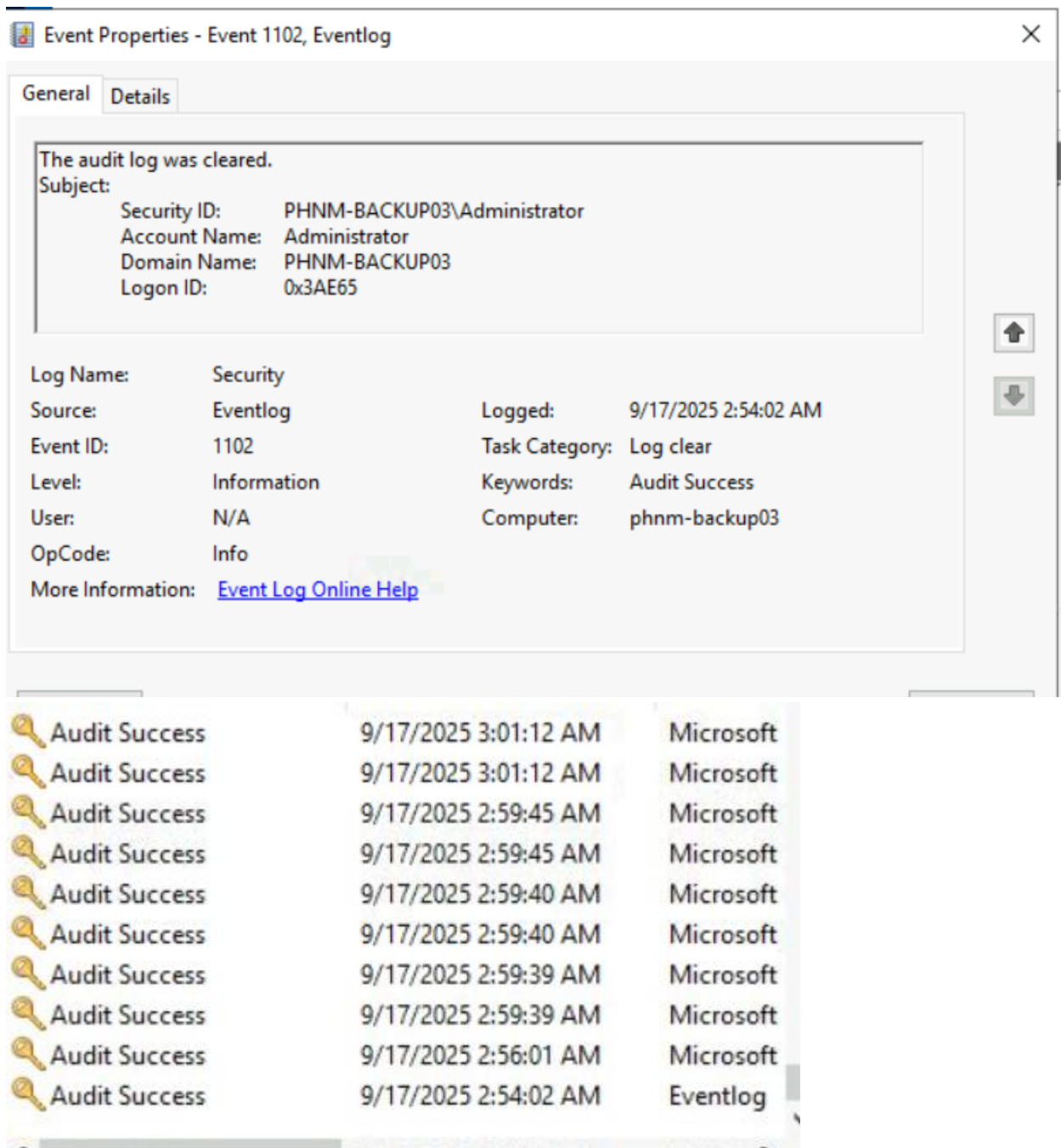
7. Command, xfreerdp /u:soc_analyst /d:PHANTOMCAP /v:10.0.242.77 /cert-ignore /p:'SOC@IncidentHandling' we access the machine



8. Utilizing known hiding places, we check the C:\Temp to find 2 zip files, used for staging and extracting client data.

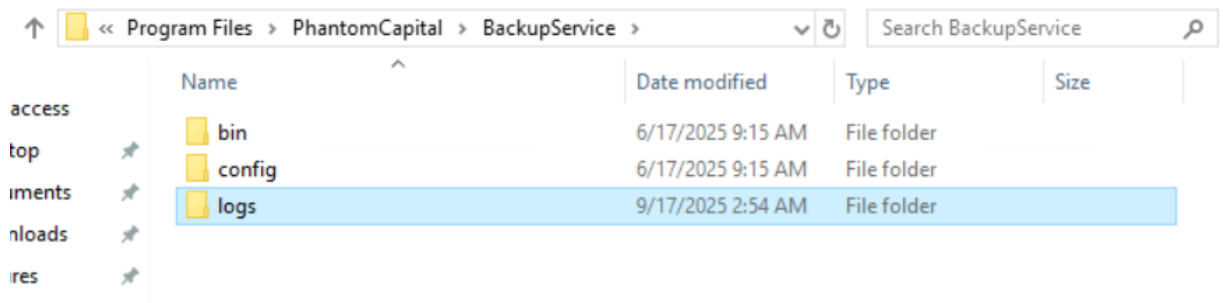


9. Finding what was stolen, we investigate eventviewer to see that the machine logs were cleared, user accounts were elevated and changed and an attempt to create a backdoor



10. These timeframes matching, it is known the attacker accessed the machine, disabled Splunk, cleared logs, elevated their own permissions and attempted to create a backdoor to access the machine at a later time.
11. Next, is to check program files for any suspicious programs, we dive into the Phantom Capital which contains a service program file named BackupService and exam the files in here, we find a .bat, an .xml and a text document log. Below are the

folders where said files reside.



12. Looking into the .bat file, it is seen that the backups are stored on a remote data base accessible via SSH and REM backups are stored at /opt/backups/

```
@echo off
REM Phantom Capital Portfolio Backup Service
REM Automated remote database backup via SSH
REM Backups are stored on the database server at /opt/backups/

set LOGFILE=C:\Program Files\PhantomCapital\BackupService\logs\backup_service.log
set CONFIGFILE=C:\Program Files\PhantomCapital\BackupService\config\config.xml

echo ===== >> "%LOGFILE%"
echo %date% %time% - Backup service started >> "%LOGFILE%"
echo ===== >> "%LOGFILE%"
```

13. Further investigation is required, looking into the .xml confirms that the backup service is located on phantomcap-findb01

```
?xml version="1.0" encoding="UTF-8"?>
BackupConfig>
  <ServiceInfo>
    <Name>PhantomCapitalBackupService</Name>
    <DisplayName>Phantom Capital Portfolio Backup Service</DisplayName>
    <Description>Automated backup service for Phantom Capital client portfolio database</Description>
  </ServiceInfo>
  <DatabaseConnection>
    <TargetServer>phantomcap-findb01.phantomcap.local</TargetServer>
    <IPAddress>10.10.50.25</IPAddress>
    <Credentials>
      <Username>phnm_backup_svc</Username>
      <Password>Phnm#2024!Bk9mL2@wX5</Password>
    </Credentials>
    <Database>phantom_portfolio_records</Database>
    <Port>3306</Port>
  </DatabaseConnection>
  <BackupSettings>
    <ScheduleDaily>ScheduleDaily</ScheduleDaily>
```

14. Needing to change machines, we ssh into the data base server using our soc_analyst user and password, enter root shell by using sudo su then go into /home/phnm_backup_svc. Using ls -la we see hidden directories, one for .bash_history, we cat .bash_history to see that there was a hidden directory named

.a followed by other directories, leading to an exfiltration.sql

```
root@ubuntu:/home/phnm_backup_svc# cat .bash_history
whoami
cd
pwd
ls -la
ps aux | grep mysql
netstat -tulpn | grep 3306
mysql -u phnm_backup_svc -p
ls -la /tmp
df -h
ls -lh /tmp
pwd
mkdir -p /home/phnm_backup_svc/.a/.a/.7f2d9c4e-3b8a-4f1e-9d6c-2a5b8e7f3c1d/.b
mysqldump -u phnm_backup_svc -p phantom_portfolio_records > /home/phnm_backup_svc/.a/.a/.7f2d9c4e-3b8a-4f1e-9d6c-2a5b8e7f3c1d/.b/exfiltration.sql
mysqldump -u phnm_backup_svc -p phantom_portfolio_records > /home/phnm_backup_svc/.a/.a/.7f2d9c4e-3b8a-4f1e-9d6c-2a5b8e7f3c1d/.b/exfiltration.sql
ls -lh /home/phnm_backup_svc/.a/.a/.7f2d9c4e-3b8a-4f1e-9d6c-2a5b8e7f3c1d/.b/
exit
root@ubuntu:/home/phnm_backup_svc#
```

15. Heading into that directory, we read the exfiltration.sql finding our flag of PHANTOM{complete_database_exfiltration_sep17_2025}, ending the activity and discovering that the whole database of Phantom has been compromised

```
oot@ubuntu:/home/phnm_backup_svc# cd /.a/.a/.7
ash: cd: /.a/.a/.7: No such file or directory
oot@ubuntu:/home/phnm_backup_svc# cd /.a/.a
ash: cd: /.a/.a: No such file or directory
oot@ubuntu:/home/phnm_backup_svc# cd .a/.a
oot@ubuntu:/home/phnm_backup_svc/.a/.a# cd .7f2d9c4e-3b8a-4f1e-9d6c-2a5b8e7f3c1d/.b
oot@ubuntu:/home/phnm_backup_svc/.a/.a/.7f2d9c4e-3b8a-4f1e-9d6c-2a5b8e7f3c1d/.b# ls
exfiltration.sql
oot@ubuntu:/home/phnm_backup_svc/.a/.a/.7f2d9c4e-3b8a-4f1e-9d6c-2a5b8e7f3c1d/.b# cat exfiltration.sql
PHANTOM{complete_database_exfiltration_sep17_2025}
oot@ubuntu:/home/phnm_backup_svc/.a/.a/.7f2d9c4e-3b8a-4f1e-9d6c-2a5b8e7f3c1d/.b#
```

Recommendations

1. Reset all user account password
2. Isolate phnm-backup03 and remove all malicious files from the database.
3. Implement an account lockout policy of 3 attempts with a 30 minute lockout.
4. Implement MFA on all accounts, especially accounts with elevated privileges.
5. Segment networks, so that the data base servers are not on the same network as backup servers.